LEARNER GUIDE

Cyber Security Awareness Workshop

Recognise threats • reduce exposure • escalate with confidence

Course Code: C506
Version 1.0 | 1 October 2026

Document control

Field	Value
Course	Cyber Security Awareness Workshop
Course code	C506
Version	1.0
Duration	1 day, 9:30am – 5:30pm (7.5 instructional hours, 0.5 hour lunch)

Document Version Control Record

Version	Effective date	Summary of included changes	Author
1.0	1 Oct 2026	Initial release of the workshop courseware	Tertiary Infotech Academy

How to use this guide

Use the slide deck to understand concepts and visual models. Use this guide for explanations, real-world case analysis, detailed lab procedures, verification criteria and transfer-to-work actions.

> **Safety boundary: Use only the named training tools and supplied mock data. Never test systems without explicit written authorisation.**

Contents

Right-click and update this field in Word to refresh the table of contents.

Course outcomes

Outcome	Performance statement	Topic
LO1	Identify cyber security risks and threats affecting people and organisations	Topic 1
LO2	Apply safeguards to protect personal information and everyday digital activity	Topic 2
LO3	Apply business safeguards and interpret incidents that require escalation	Topic 3

Core language

Asset

Anything valuable to a person or organisation, including identity, device, data, service, money, reputation and safety.

Threat

A person, event or mechanism capable of causing harm.

Vulnerability

A weakness, insecure feature, configuration or human process that can be exploited.

Exploit

A technique or code that takes advantage of a vulnerability.

Risk

The likelihood and consequence of harm in context, after considering existing controls.

Control

A safeguard that prevents, detects, contains, corrects or supports recovery.

Source: NCSC — Understanding vulnerabilities

Topic 1 — Identify cyber security risks and threats

Cyber incidents are sequences, not isolated technical labels. A useful analysis identifies the valuable asset, the actor or mechanism, the weakness, the observable evidence and the likely business impact. This avoids two common errors: treating every alert as a crisis and dismissing weak signals that form a credible chain when combined.

Threat actors and motives

Actor	Typical motive	Awareness implication
Cybercriminal	Fraud, theft, extortion and resale	High-volume attempts coexist with targeted BEC and ransomware.
Insider	Malice, coercion or accidental misuse	Legitimate access can still create risk; focus on behaviour and least privilege.
Hacktivist	Visibility, disruption or disclosure	Public-facing systems and reputation may be targeted.

Actor	Typical motive	Awareness implication
Nation-state / APT	Strategic intelligence or persistent access	Low-noise activity, suppliers and privileged identities matter.
Opportunist	Exploit exposed systems at scale	Basic hygiene closes many automated attack paths.

Malware types and characteristics

Type	Core behaviour	Warning signs	First defensive priority
Virus	Attaches to a host file and executes when the file runs	Unexpected file changes; antivirus detections	Block execution, isolate, restore clean copies
Worm	Self-propagates across reachable systems	Rapid scanning and repeated connections	Segment, patch, isolate affected segments
Trojan	Disguises malicious capability as legitimate software	Untrusted installer, new process or persistence	Application control, trusted sources, EDR
Ransomware	Encrypts or disrupts systems and demands payment	File extensions change, ransom note, unavailable services	Isolate, preserve evidence, activate response and recovery
Spyware	Collects activity, credentials or data covertly	Browser changes, unusual outbound traffic	Remove persistence, reset credentials safely
Rootkit	Hides privileged malicious activity	Integrity anomalies, unexplained privileged changes	Offline investigation, rebuild trusted baseline
Bot	Places a device under remote command	Beaconing, DDoS or spam activity	Block command-and-control, isolate, remediate
Logic bomb	Triggers a malicious action when a condition is met	Scheduled or conditional destructive code	Code review, least privilege, change control
Adware	Displays intrusive advertising and may track browsing or alter settings	Persistent pop-ups, redirects and unwanted extensions	Remove unwanted software, review permissions, use trusted sources
Keylogger	Records keystrokes to capture credentials and sensitive input	Unexplained input hooks, suspicious processes or credential theft	Endpoint protection, MFA, safe rebuild and credential reset
Fileless malware	Abuses memory and legitimate administration tools instead of relying on a normal file	Unexpected PowerShell, script hosts, encoded commands or memory activity	Restrict scripting, monitor behaviour, least privilege, EDR
Cryptojacker	Hijacks computing resources to mine cryptocurrency	High CPU or cloud cost, overheating and unknown mining connections	Patch entry points, control scripts, monitor resource use and cloud spend

Malware family explanations

Virus. Behaviour: Attaches to a host file and executes when the file runs. Observable evidence: Unexpected file changes; antivirus detections. First defensive priority: Block execution, isolate, restore clean copies. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Worm. Behaviour: Self-propagates across reachable systems. Observable evidence: Rapid scanning and repeated connections. First defensive priority: Segment, patch, isolate affected segments. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Trojan. Behaviour: Disguises malicious capability as legitimate software. Observable evidence: Untrusted installer, new process or persistence. First defensive priority: Application control, trusted sources, EDR. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Ransomware. Behaviour: Encrypts or disrupts systems and demands payment. Observable evidence: File extensions change, ransom note, unavailable services. First defensive priority: Isolate, preserve evidence, activate response and recovery. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Spyware. Behaviour: Collects activity, credentials or data covertly. Observable evidence: Browser changes, unusual outbound traffic. First defensive priority: Remove persistence, reset credentials safely. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Rootkit. Behaviour: Hides privileged malicious activity. Observable evidence: Integrity anomalies, unexplained privileged changes. First defensive priority: Offline investigation, rebuild trusted baseline. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Bot. Behaviour: Places a device under remote command. Observable evidence: Beaconing, DDoS or spam activity. First defensive priority: Block command-and-control, isolate, remediate. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Logic bomb. Behaviour: Triggers a malicious action when a condition is met. Observable evidence: Scheduled or conditional destructive code. First defensive priority: Code review, least privilege, change control. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Adware. Behaviour: Displays intrusive advertising and may track browsing or alter settings. Observable evidence: Persistent pop-ups, redirects and unwanted extensions. First defensive priority: Remove unwanted software, review permissions, use trusted sources. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Keylogger. Behaviour: Records keystrokes to capture credentials and sensitive input. Observable evidence: Unexplained input hooks, suspicious processes or credential theft. First defensive priority: Endpoint protection, MFA, safe rebuild and credential reset. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Fileless malware. Behaviour: Abuses memory and legitimate administration tools instead of relying on a normal file. Observable evidence: Unexpected PowerShell, script hosts, encoded commands or memory activity. First defensive priority: Restrict scripting, monitor behaviour, least privilege, EDR. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Cryptojacker. Behaviour: Hijacks computing resources to mine cryptocurrency. Observable evidence: High CPU or cloud cost, overheating and unknown mining connections. First defensive priority: Patch entry points, control scripts, monitor resource use and cloud spend. *Treat the label as a working hypothesis until multiple sources of evidence agree.*

Do not diagnose from one symptom. Separate observable facts from the hypothesis, preserve evidence, and escalate when the potential impact is high or the activity may be spreading.

Source: CrowdStrike — Types of malware

Social engineering and BEC

Social engineering uses authority, urgency, fear, scarcity, familiarity or secrecy to change a decision. Business email compromise is especially dangerous because a message may contain no malware: the attack succeeds when a trusted workflow accepts a fraudulent instruction.

Type	Everyday example	How it works	Red flags	Safe response
Phishing	'Your parcel is waiting. Pay S$1.20 at parcel-status.example.test within 30 minutes.'	Broad deceptive email seeks clicks, credentials, payments or malware execution	Generic urgency, mismatched link, unexpected attachment	Use a known route to the service; report the message
Spear phishing	'Hi Mei, I saw your Project Atlas post. Open the attached revised budget before today's client call.'	A tailored message uses role, project or relationship details to appear credible	Accurate context paired with an unusual request or channel	Verify the request with the known person using another channel
Whaling	'The chairman needs the confidential acquisition file now. Send it to this private address and do not copy anyone.'	A high-value executive or decision-maker is specifically targeted	Legal, finance or board urgency; secrecy; authority pressure	Executive verification protocol and delegated dual approval
Business email compromise	'We changed banks. Pay invoice INV-2048 to the new account today; reply only to this email.'	An attacker impersonates or takes over a trusted mailbox to change a business transaction	New bank details, lookalike domain, altered reply-to or unusual timing	Independent call-back using stored contacts; dual approval
Smishing	'Bank alert: your account is locked. Tap bank-verify.example.test now.'	SMS or messaging platforms deliver fraudulent links, codes or support requests	Delivery, bank or government lure with shortened link and urgency	Open the official app or known website instead of the message link
Vishing	'I'm from the bank fraud team. Read me the six-digit code so I can cancel the transfer.'	A caller impersonates authority, support, a bank or a colleague to obtain action or secrets	Caller pressure, request for codes, remote access or immediate payment	End the call and dial a known official number

Type	Everyday example	How it works	Red flags	Safe response
QR phishing / quishing	A parking notice says ‘Scan to avoid a fine’, but the QR destination is pay-parking.example.test.	A QR code hides the destination and moves the victim onto a mobile browser	Unsolicited QR code near payment, login, parking or document access	Preview the destination; use a known app or typed address
Pretexting	A caller claims to be a new auditor and asks for the staff list and VPN guide ‘for tomorrow's inspection’.	A fabricated role and story creates a reason to disclose data or bypass process	Detailed story but weak entitlement, unusual data request or exception	Verify identity, authority and need-to-know separately
Baiting	A USB labelled ‘2026 Salary Review’ is left beside the office printer.	An attractive download, prize or abandoned device tempts the victim to interact	Free software, found USB media or exclusive content	Do not connect unknown media; use approved software sources
Quid pro quo	A stranger offers free IT support but asks you to install a remote-control app and share your login code.	A promised benefit or service is exchanged for credentials, access or information	Unexpected help offer that asks for a password, code or installation	Use the official support channel and never disclose authenticators
Tech-support scam	A browser pop-up says ‘Virus detected—call support now’ and the caller asks for remote access.	Fake support persuades the victim to install remote-control software or pay for a nonexistent problem	Unsolicited warning, remote-access request and pressure to keep the call secret	Disconnect, remove remote access safely and contact genuine support
Tailgating	Someone carrying boxes asks you to hold the secure door because ‘my access card is in the car’.	An unauthorised person follows an authorised user through a controlled entrance	Visitor avoids reception or relies on politeness and a carried object	Challenge politely or escort the person to reception
Shoulder surfing	A stranger watches you enter a phone PIN on a crowded train, then follows where you keep the device.	Information is observed directly from screens, keyboards, documents or conversations	Crowded space, exposed screen or sensitive conversation	Use privacy awareness, screen positioning and clean-desk habits
Dumpster diving	Printed customer labels and an old USB drive are placed in ordinary rubbish.	Discarded documents or devices reveal identities, systems or business information	Sensitive printouts, labels or storage media in normal waste	Secure disposal, shredding and verified media destruction
Watering-hole deception	A familiar industry forum suddenly asks you to install a ‘document viewer’ before reading a post.	A site trusted by a target community is compromised or imitated to reach that group	Unexpected login, download or browser warning on a familiar niche site	Patch browsers, limit execution and verify unusual site behaviour
MFA fatigue / push bombing	Your phone shows six login approvals, then ‘IT support’ calls and tells you to approve the next one.	Repeated authentication prompts pressure a user to approve one to make them stop	Multiple unexpected prompts followed by a call claiming to be support	Deny, report, change credentials and prefer number matching or passkeys

Different labels can overlap. For example, a spear-phishing message may use a pretext, move to a vishing call and finish with MFA push bombing. Analyse the complete manipulation path rather than arguing over one label.

- Inspect the exact sender domain, reply-to, destination and request — not only the display name.
- Treat changes to bank details, payroll, recovery contacts or privileged access as high-risk transactions.
- Verify through a previously known channel. Never use contact details contained only in the suspicious message.
- Apply dual approval and transaction limits so one manipulated person cannot complete the loss.
- Escalate quickly to the bank and relevant authorities when money may have moved.

Source: Singapore Police Force — 2026 BEC recovery case

Beginner example gallery

These are synthetic classroom examples, not live messages. Read the request first, identify the clues, then choose a safer route that the sender or caller cannot control.

Channel	What the learner sees	Clues to discuss	Safer response
Email	We could not deliver your parcel. Pay S$1.20 within 30 minutes or it will be returned.	Unexpected small payment; Sender and reply-to differ; Urgency creates pressure; Link is not the courier's known site	Open the courier's official app or type its known address. Do not use the email link.
Email	Sign in now to keep your medical benefits. You have 20 minutes before access is removed.	Threat of losing access; Unusual external reply-to; Unexpected sign-in link; No matching notice in the HR portal	Use the bookmarked HR portal or call HR on the directory number.

Channel	What the learner sees	Clues to discuss	Safer response
Email	Our bank account changed today. Please pay S$48,700 to the attached account before 3 pm. Reply only to this email.	Lookalike domain uses the digit 1; Bank details changed; Same-day payment pressure; Request bypasses normal verification	Stop payment and call the supplier using the number already stored in the vendor record.
SMS	BANK SECURITY: Your account is locked. Verify now at bank-verify.example.test or access will be suspended.	Fear of account loss; Link asks for a bank login; Generic sender name; Message is unexpected	Open the official banking app independently and use its support number if needed.
Phone call	Caller: 'There is a S$2,900 transfer pending. Read me the six-digit code now so I can cancel it.'	Caller creates fear; Requests an authentication code; Demands immediate action; Caller ID can be spoofed	End the call. Dial the number on the back of the bank card or in the official app.
QR poster	PARKING NOTICE: Scan now to pay a S$4.00 fee and avoid a S$70 fine. Destination preview: pay-parking.example.test	Sticker may cover a genuine code; Destination is hidden until scanning; Fine creates urgency; Site is not the known parking operator	Use the official parking app or type the operator's known address.
Authentication app	Six login approval prompts arrive, followed by a call: 'This is IT. Approve the next one to stop the alerts.'	You did not start a login; Prompts repeat; A caller asks you to approve; Approval would authorise the attacker	Deny, report the prompts, change the password from a trusted device and review active sessions.
Workplace	Tailgating: a person carrying boxes asks you to hold a secure door. Pretexting: a 'new auditor' asks for the staff list and VPN guide.	Politeness is used as pressure; No visible access or appointment; Role sounds plausible but is unverified; Request exceeds need-to-know	Escort the person to reception and verify identity, appointment, authority and need-to-know.

Network, mobile and availability threats

Threat	What happens	Practical response
Passive observation	Traffic patterns or content are observed	Use trusted networks and encrypted services; minimise sensitive exposure.
Man-in-the-middle	Communication is intercepted or altered	Verify destinations and certificates; use secure protocols; stop on warnings.
DDoS	Capacity is exhausted and service becomes unavailable	Use upstream filtering, rate limits, capacity plans and provider escalation.
Rogue wireless	A fake or unsafe network attracts users	Verify network identity; prefer mobile data for sensitive work.
Mobile account takeover	SIM, recovery or MFA workflows are abused	Strengthen recovery, use passkeys/security keys, review sessions and alerts.

Real-world case studies

The cases below are used to transfer patterns into present-day decisions. The attack detail is intentionally defensive: entry path, exploited weakness, impact, observable signals, controls and lesson. Use each case as an eight-minute decision-room discussion: two minutes to read, four minutes to decide, and two minutes to brief the class.

Discussion role	Responsibility
Incident lead	Set the immediate priority and state the decision required.
Evidence lead	Separate confirmed facts, indicators and hypotheses.
Business owner	Explain operational, financial, customer and safety consequences.
Control owner	Name the control to verify and the evidence that would prove it works.

Case 1: SingHealth data breach (Singapore, 2018)

Lens	Analysis
Entry path	Compromised front-end workstation and privileged credentials
Exploited weakness	Endpoint compromise, credential misuse, delayed detection

Lens	Analysis
Impact	Personal particulars of 1.5 million patients; outpatient medication records of 160,000
Defender signals	Unusual database queries, privileged access, suspicious workstation activity
Controls	Endpoint hardening, least privilege, privileged access monitoring, segmented systems, rehearsed response
Transferable lesson	Identity and endpoint signals must be connected before an intruder reaches sensitive data.

Source: Ministry of Health Singapore — SingHealth's IT System Target of Cyberattack

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unusual database queries, privileged access, suspicious workstation activity?
- Decision: Which immediate action limits the stated impact without destroying evidence — Personal particulars of 1.5 million patients; outpatient medication records of 160,000?
- Control: Which one control from this set should be verified first — Endpoint hardening, least privilege, privileged access monitoring, segmented systems, rehearsed response?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 2: WannaCry and the NHS (United Kingdom, 2017)

Lens	Analysis
Entry path	Ransomware exploited unpatched Windows systems
Exploited weakness	Patch gaps, unsupported systems, uneven asset visibility
Impact	Disruption across NHS organisations and cancelled care
Defender signals	Rapid lateral spread, inaccessible files, ransom notes, unavailable clinical systems
Controls	Asset inventory, timely patching, supported platforms, segmentation, tested offline recovery
Transferable lesson	A known vulnerability becomes an operational crisis when ownership and patching fail.

Source: UK National Audit Office — Investigation: WannaCry Cyber Attack and the NHS

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Rapid lateral spread, inaccessible files, ransom notes, unavailable clinical systems?
- Decision: Which immediate action limits the stated impact without destroying evidence — Disruption across NHS organisations and cancelled care?
- Control: Which one control from this set should be verified first — Asset inventory, timely patching, supported platforms, segmentation, tested offline recovery?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 3: Equifax breach (United States, 2017)

Lens	Analysis
Entry path	Exploitation of a known web application vulnerability
Exploited weakness	Patch and asset-management breakdowns
Impact	Sensitive personal information exposed at massive scale
Defender signals	Unusual web traffic and data access; vulnerable internet-facing service
Controls	Complete asset inventory, vulnerability SLAs, compensating controls, verification after patching
Transferable lesson	A patch notice is not a control until the affected asset is found, fixed and verified.

Source: U.S. House Committee on Oversight — The Equifax Data Breach

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unusual web traffic and data access; vulnerable internet-facing service?
- Decision: Which immediate action limits the stated impact without destroying evidence — Sensitive personal information exposed at massive scale?
- Control: Which one control from this set should be verified first — Complete asset inventory, vulnerability SLAs, compensating controls, verification after patching?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 4: SolarWinds supply-chain compromise (Global, 2020)

Lens	Analysis
Entry path	Malicious code inserted into trusted software updates
Exploited weakness	Implicit trust in supplier software and privileged management tooling
Impact	Covert access to public- and private-sector networks
Defender signals	Rare identity use, unusual cloud access, unexpected network paths
Controls	Supplier risk management, zero-trust checks, identity analytics, egress monitoring, rapid key rotation
Transferable lesson	Trusted software can carry risk; verify behaviour after deployment, not only the publisher.

Source: CISA — Active Exploitation of SolarWinds Software

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Rare identity use, unusual cloud access, unexpected network paths?
- Decision: Which immediate action limits the stated impact without destroying evidence — Covert access to public- and private-sector networks?
- Control: Which one control from this set should be verified first — Supplier risk management, zero-trust checks, identity analytics, egress monitoring, rapid key rotation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 5: Colonial Pipeline (United States, 2021)

Lens	Analysis
Entry path	Compromised VPN password on an inactive account without MFA
Exploited weakness	Dormant identity, password reuse/exposure, missing MFA
Impact	Business systems disruption and precautionary pipeline shutdown
Defender signals	Unexpected remote access and activity from a dormant account
Controls	Disable dormant accounts, MFA, password monitoring, remote-access review, IT/OT separation
Transferable lesson	Identity hygiene is infrastructure resilience.

Source: CISA — IAM Case Study: Colonial Pipeline

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unexpected remote access and activity from a dormant account?
- Decision: Which immediate action limits the stated impact without destroying evidence — Business systems disruption and precautionary pipeline shutdown?
- Control: Which one control from this set should be verified first — Disable dormant accounts, MFA, password monitoring, remote-access review, IT/OT separation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 6: Log4Shell exploitation (Global, 2021)

Lens	Analysis
Entry path	Remote code execution through a widely embedded logging component
Exploited weakness	Hidden software dependency and incomplete inventory
Impact	Broad exploitation risk across internet-facing systems
Defender signals	Suspicious lookup strings, outbound callbacks, new processes and payloads
Controls	Software bill of materials, emergency patch process, virtual patching, threat hunting
Transferable lesson	You cannot protect a component you do not know you run.

Source: CISA — Mitigating Log4Shell and Log4j Vulnerabilities

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Suspicious lookup strings, outbound callbacks, new processes and payloads?
- Decision: Which immediate action limits the stated impact without destroying evidence — Broad exploitation risk across internet-facing systems?
- Control: Which one control from this set should be verified first — Software bill of materials, emergency patch process, virtual patching, threat hunting?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 7: MOVEit mass exploitation (Global, 2023)

Lens	Analysis
Entry path	Zero-day SQL injection in managed file-transfer software
Exploited weakness	Internet-facing data service and third-party concentration
Impact	Data theft across many organisations through one common platform
Defender signals	Unexpected database queries, web shells, unusual downloads and new accounts
Controls	Vendor advisories, rapid isolation, compromise assessment, third-party exposure mapping
Transferable lesson	Third-party software can multiply one vulnerability into sector-wide exposure.

Source: CISA — CL0P Exploits MOVEit Vulnerability

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unexpected database queries, web shells, unusual downloads and new accounts?
- Decision: Which immediate action limits the stated impact without destroying evidence — Data theft across many organisations through one common platform?
- Control: Which one control from this set should be verified first — Vendor advisories, rapid isolation, compromise assessment, third-party exposure mapping?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 8: MGM Resorts cyber incident (United States, 2023)

Lens	Analysis
Entry path	Identity compromise followed by system disruption
Exploited weakness	Help-desk and identity-recovery processes exposed to manipulation
Impact	Systems shut down, service disruption and personal data exposure
Defender signals	Unusual identity recovery, privileged account changes and abrupt service outages
Controls	High-assurance help-desk verification, phishing-resistant MFA, privileged identity monitoring
Transferable lesson	Recovery workflows need controls as strong as login workflows.

Source: U.S. Securities and Exchange Commission — MGM Resorts International Form 8-K

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unusual identity recovery, privileged account changes and abrupt service outages?
- Decision: Which immediate action limits the stated impact without destroying evidence — Systems shut down, service disruption and personal data exposure?
- Control: Which one control from this set should be verified first — High-assurance help-desk verification, phishing-resistant MFA, privileged identity monitoring?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 9: Singapore commodity-trader BEC (Singapore, 2026)

Lens	Analysis
Entry path	Supplier impersonation using a subtly transposed email domain
Exploited weakness	Payment change accepted without independent verification
Impact	USD 6.6 million transferred; funds recovered after rapid reporting and international cooperation
Defender signals	Changed bank details, lookalike domain, urgency and unusual payment instructions
Controls	Call-back verification using known contacts, dual approval, domain checks, rapid bank and police escalation
Transferable lesson	A two-minute independent check can prevent a multi-million-dollar loss.

Source: Singapore Police Force — Recovery of Over USD 6.6 Million in BEC Case

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Changed bank details, lookalike domain, urgency and unusual payment instructions?
- Decision: Which immediate action limits the stated impact without destroying evidence — USD 6.6 million transferred; funds recovered after rapid reporting and international cooperation?
- Control: Which one control from this set should be verified first — Call-back verification using known contacts, dual approval, domain checks, rapid bank and police escalation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 10: Target payment-card breach (United States, 2013)

Lens	Analysis
Entry path	Stolen third-party vendor credentials enabled access into the retailer environment
Exploited weakness	Supplier access, weak separation and missed opportunities to act on security alerts
Impact	Payment-card information and personal data associated with tens of millions of customers were exposed
Defender signals	Malware alerts, unusual internal movement and outbound data transfers
Controls	Supplier MFA, segmented vendor access, alert ownership, egress monitoring and tested incident escalation
Transferable lesson	A low-privilege supplier pathway can become a high-impact route when trust boundaries are weak.

Source: U.S. Senate Committee on Commerce — Target's Missed Opportunities to Stop a Data Breach

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Malware alerts, unusual internal movement and outbound data transfers?
- Decision: Which immediate action limits the stated impact without destroying evidence — Payment-card information and personal data associated with tens of millions of customers were exposed?
- Control: Which one control from this set should be verified first — Supplier MFA, segmented vendor access, alert ownership, egress monitoring and tested incident escalation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 11: NotPetya disruption at Maersk (Global shipping, 2017)

Lens	Analysis
Entry path	Destructive malware entered through compromised Ukrainian accounting software and spread globally
Exploited weakness	Trusted software pathway, flat connectivity and operational dependence on shared digital services
Impact	Global applications and data were unavailable for days; port and shipping operations were disrupted
Defender signals	Rapid cross-site outages, unavailable systems and destructive behaviour rather than a recoverable ransom event
Controls	Supplier risk controls, segmentation, isolated recovery capability, offline identity services and business workarounds
Transferable lesson	An organisation can suffer severe collateral damage even when it is not the intended target.

Source: UK Department for Transport — Cyber Security for Ports and Port Systems

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Rapid cross-site outages, unavailable systems and destructive behaviour rather than a recoverable ransom event?
- Decision: Which immediate action limits the stated impact without destroying evidence — Global applications and data were unavailable for days; port and shipping operations were disrupted?
- Control: Which one control from this set should be verified first — Supplier risk controls, segmentation, isolated recovery capability, offline identity services and business workarounds?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 12: Marriott Starwood data breach (Global hospitality, disclosed 2018)

Lens	Analysis
Entry path	Long-running unauthorised access in an acquired reservation environment
Exploited weakness	Acquisition due diligence, legacy-system monitoring and delayed detection
Impact	Large-scale exposure of guest records and sustained regulatory and customer consequences
Defender signals	Compromised accounts, database activity and anomalous access within a legacy environment
Controls	Pre-acquisition security assurance, rapid integration, identity reset, continuous monitoring and data minimisation
Transferable lesson	Cyber risk transfers with an acquisition unless inherited systems and identities are independently verified.

Source: UK Information Commissioner's Office — Marriott International Monetary Penalty Notice

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Compromised accounts, database activity and anomalous access within a legacy environment?

- Decision: Which immediate action limits the stated impact without destroying evidence — Large-scale exposure of guest records and sustained regulatory and customer consequences?
- Control: Which one control from this set should be verified first — Pre-acquisition security assurance, rapid integration, identity reset, continuous monitoring and data minimisation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 13: Capital One cloud data breach (United States, 2019)

Lens	Analysis
Entry path	A misconfigured web application firewall enabled access to cloud-hosted data
Exploited weakness	Cloud configuration and permission design allowed excessive access
Impact	Data from millions of credit applications was accessed
Defender signals	Unexpected cloud API activity, unusual data access and exploitation of an internet-facing control
Controls	Least-privilege cloud roles, configuration assurance, logging, anomaly detection and rapid credential revocation
Transferable lesson	Cloud services inherit the organisation's configuration decisions; provider security does not remove customer responsibility.

Source: U.S. Department of Justice — Seattle Tech Worker Arrested for Data Theft

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unexpected cloud API activity, unusual data access and exploitation of an internet-facing control?
- Decision: Which immediate action limits the stated impact without destroying evidence — Data from millions of credit applications was accessed?
- Control: Which one control from this set should be verified first — Least-privilege cloud roles, configuration assurance, logging, anomaly detection and rapid credential revocation?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 14: Norsk Hydro LockerGoga ransomware (Norway and global operations, 2019)

Lens	Analysis
Entry path	Ransomware disrupted corporate and operational workstations
Exploited weakness	Enterprise connectivity allowed IT disruption to affect industrial operations
Impact	Plants shifted to manual workarounds while systems were rebuilt and restored
Defender signals	Unavailable workstations, encryption activity and loss of normal production-support systems
Controls	IT/OT segmentation, rehearsed manual operations, clean rebuild capability, transparent communications and tested backups
Transferable lesson	Operational resilience includes safe manual workarounds, not only technical restoration.

Source: UK National Cyber Security Centre — What Is OT Malware?

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Unavailable workstations, encryption activity and loss of normal production-support systems?
- Decision: Which immediate action limits the stated impact without destroying evidence — Plants shifted to manual workarounds while systems were rebuilt and restored?
- Control: Which one control from this set should be verified first — IT/OT segmentation, rehearsed manual operations, clean rebuild capability, transparent communications and tested backups?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Case 15: Change Healthcare cyberattack (United States healthcare, 2024)

Lens	Analysis
Entry path	Threat actor access led the organisation to isolate connected transaction systems
Exploited weakness	Sector-wide dependence on a concentrated claims and payment intermediary
Impact	Electronic claims, payments and pharmacy transactions were disrupted across healthcare providers
Defender signals	Service interruption across connected customers and loss of access to transactional networks
Controls	Strong remote-access identity, supplier concentration analysis, alternate clearing routes, isolation plans and recovery communications
Transferable lesson	A cyber incident at one digital intermediary can become a cash-flow and patient-service crisis across an ecosystem.

Source: U.S. Securities and Exchange Commission — UnitedHealth Group Form 8-K, 21 February 2024

Class discussion

- Triage: Which part of this signal set would you trust first, and why — Service interruption across connected customers and loss of access to transactional networks?
- Decision: Which immediate action limits the stated impact without destroying evidence — Electronic claims, payments and pharmacy transactions were disrupted across healthcare providers?
- Control: Which one control from this set should be verified first — Strong remote-access identity, supplier concentration analysis, alternate clearing routes, isolation plans and recovery communications?
- Transfer: Where could the same entry path exist in a personal account, supplier relationship or small business today?

Brief-back standard: state the situation, confirmed evidence, likely impact, immediate safe action, uncertainty and the decision or authority required.

Topic 2 — Protect personal information

Personal safeguards work as a system. Strong authentication cannot rescue an unsupported device indefinitely; a patched device cannot prevent a fraudulent payment if the process accepts unverified changes. Layer identity, device, data, network, people and recovery controls.

Identity and authentication

- Use a unique long passphrase for every service and store it in a reputable password manager.
- Use MFA; prefer phishing-resistant passkeys or hardware security keys for high-value accounts.

- Do not approve unexpected MFA prompts. Review active sessions, recovery methods and connected applications.
- Change credentials when compromise is suspected or confirmed; routine forced changes can encourage predictable passwords.
- Disable dormant accounts and remove access that is no longer needed.

Device baseline

Lifecycle point	Safeguard	Verification
Acquire	Supported hardware and trusted software source	Confirm vendor support date and authentic installer.
Configure	Encryption, standard user, screen lock, least permissions	Check settings and test lock/recovery.
Maintain	Automatic OS, browser, app and firmware updates	Review update status and failed installations.
Monitor	Account, endpoint and security alerts	Know who receives alerts and test one notification path.
Retire	Backup, sign out, wipe and verify	Confirm data cannot be recovered by normal means.

Backups and recovery

Use the 3–2–1 pattern as a starting point: three copies, two media or locations, and one offline or immutable copy. Define what must be restored first and how much data loss is tolerable. Test a restore; a successful backup job does not prove recoverability.

Safer online activity

- Use bookmarks or manually entered known addresses for banking, government and business administration.
- Treat HTTPS as connection protection, not proof that a seller or message is legitimate.
- Use transaction alerts, limits and trusted payment channels; pause when bank details change.
- Share the minimum personal information required and review app permissions periodically.
- On public networks, prefer mobile data for sensitive work and avoid unexpected captive portals.

Topic 3 — Protect business information

Business cybersecurity combines technical controls with ownership, workflow design, supplier management, evidence and recovery. The objective is not to remove all risk; it is to keep risk within an authorised tolerance and respond before harm expands.

Vulnerable areas and controls

Area	Why vulnerable	Risk treatment
Unpatched software	Known flaw remains exploitable	Asset inventory + risk-based patch SLA
Weak or reused credentials	One stolen secret unlocks several services	Password manager + MFA/passkeys + breach response
Excess privilege	Compromise reaches more data and systems	Least privilege + access reviews
Misconfiguration	Security feature exists but is unsafe	Secure baseline + continuous configuration checks
Internet exposure	Attack surface is reachable by anyone	Minimise services + strong authentication + monitoring
Unsafe input handling	Application trusts hostile input	Validation + parameterised queries + testing

Area	Why vulnerable	Risk treatment
Third-party dependency	Supplier weakness becomes customer exposure	Supplier inventory + contract controls + monitoring
Human process gap	Urgency or authority bypasses verification	Independent verification + dual approval + rehearsal

Source: NCSC — Understanding vulnerabilities

Risk-based prioritisation

Do not rank by severity alone. Combine technical severity with internet reachability, sensitive data, operational criticality, active exploitation, available safeguards and recovery options. Record the treatment owner, due date and verification method.

Web, detection and authorised testing

Capability	Purpose	Key governance point
Secure development	Prevent injection, access-control and configuration failures	Validate on the server; use parameterised queries; test before release.
IDS / IPS	Detect or block suspicious network patterns	Rules need context, ownership, tuning and safe automated actions.
Endpoint detection	Connect process, identity, file and network behaviour	Preserve evidence and define containment authority.
Honeypot	Reveal activity that has no legitimate reason to occur	Isolate carefully; do not treat it as a replacement for controls.
Penetration test	Authorised validation of exploitable weakness	Written scope, rules, stop conditions, evidence handling and remediation.

Source: OWASP — SQL injection

Incident escalation

Escalate immediately when safety, essential services, sensitive data, privileged identities, money movement, active spread or high-impact uncertainty is involved. A strong handover states situation, evidence, business impact, actions taken, uncertainty and the decision or support required.

Field	Question
Situation	What is happening now and when was it first observed?
Evidence	What facts, indicators and records support the concern?
Impact	Which people, data, services, money or obligations are affected?
Action	What safe containment or evidence-preservation steps have been taken?
Decision	What authority, resource, external contact or communication is required?
Uncertainty	Which statements are inference and what would confirm them?

Hands-on labs

The following lab procedures are reproduced from the same single-source definitions used to create each lab folder. Submit only synthetic evidence. Detailed step sequences intentionally appear here and in the lab packs, not in the presentation.

Lab-01: Threat Triage with the Cybersecurity Simulator

Field	Detail
Time	25 minutes
Alignment	LO1
Tool	Cybersecurity Simulator
Scenario	A small Singapore design agency receives five mixed security alerts. Decide what is benign, suspicious or urgent.
Mock data	mock-threat-events.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/cybersecuritysimulator/

Procedure

1. Open mock-threat-events.csv and read all five events before classifying any one event.
2. Open the Cybersecurity Simulator and select the closest scenario for each event.
3. For every event, record the asset, threat actor or mechanism, observable signal and potential business impact.
4. Assign a severity from 1 to 5 using likelihood and impact; explain one uncertainty in your score.
5. Choose the first safe action: observe, contain, verify with the user, isolate the device, or escalate.
6. Capture one screenshot of your highest-risk decision and export your completed triage table.

Evidence and acceptance criteria

- Completed triage table — complete, legible, based only on mock data, and traceable to the decision made.
- Severity rationale — complete, legible, based only on mock data, and traceable to the decision made.
- Screenshot of highest-risk decision — complete, legible, based only on mock data, and traceable to the decision made.
- One escalation statement — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-02: Detect Phishing and Business Email Compromise

Field	Detail
Time	35 minutes
Alignment	LO1, LO3
Tool	Cybersecurity Simulator + Regex Generator
Scenario	Accounts staff must detect a lookalike supplier domain before approving a high-value transfer.
Mock data	mock-inbox.csv, mock-approved-domains.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/regexgenerator/

Procedure

1. Compare each sender domain in mock-inbox.csv with the approved supplier domains; inspect every character.
2. Mark persuasion cues such as urgency, authority, secrecy, changed payment details and unusual attachments.
3. Use Regex Generator to create a pattern that flags the supplied lookalike-domain examples without matching the approved domains.
4. Test the expression on every sample; record true positives, false positives and false negatives.
5. Draft a safe verification message and a call-back procedure that uses a previously known contact channel.
6. Decide which emails require immediate escalation and name the recipient role, urgency and evidence to include.

Evidence and acceptance criteria

- Annotated inbox — complete, legible, based only on mock data, and traceable to the decision made.
- Tested regex — complete, legible, based only on mock data, and traceable to the decision made.
- Detection test results — complete, legible, based only on mock data, and traceable to the decision made.
- Independent verification script — complete, legible, based only on mock data, and traceable to the decision made.
- Escalation decision — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-03: Recognise Malware and Endpoint Warning Signs

Field	Detail
Time	30 minutes
Alignment	LO1, LO3
Tool	Cybersecurity Simulator
Scenario	Endpoint alerts reveal suspicious processes, persistence and outbound connections on an employee laptop.
Mock data	mock-endpoint-alerts.json
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/cybersecuritysimulator/

Procedure

1. Review each endpoint alert without opening or executing any referenced file.
2. Map the observable behaviour to a likely malware category: ransomware, trojan, spyware, worm, bot or rootkit.
3. Separate evidence from inference; identify what additional safe telemetry would confirm the hypothesis.
4. Build a short attack chain from initial access through execution, persistence and command-and-control.
5. Choose containment actions that preserve evidence and avoid spreading the infection.
6. Prepare a concise escalation note using who, what, when, where, impact and action already taken.

Evidence and acceptance criteria

- Malware classification — complete, legible, based only on mock data, and traceable to the decision made.
- Attack-chain map — complete, legible, based only on mock data, and traceable to the decision made.
- Evidence vs inference notes — complete, legible, based only on mock data, and traceable to the decision made.
- Containment decision — complete, legible, based only on mock data, and traceable to the decision made.
- Escalation note — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-04: Prioritise Vulnerabilities by Business Risk

Field	Detail
Time	35 minutes
Alignment	LO1
Tool	Ethical Hacking Simulator
Scenario	An SME has limited maintenance time and must decide which exposures to address first.
Mock data	mock-vulnerability-register.csv, mock-asset-context.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/ethnicalhacking/

Procedure

1. Review each vulnerability together with asset owner, internet exposure, data sensitivity and operational criticality.
2. Use the simulator only in its authorised training environment to observe how attack preconditions change risk.
3. Calculate risk as likelihood × impact, then adjust the score for active exploitation, reachability and control strength.
4. Rank the vulnerabilities and state why severity alone does not determine business priority.
5. Select a treatment: patch, isolate, disable, add a compensating control, accept temporarily or retire the asset.
6. Set an owner, due date and verification method for the top three actions.

Evidence and acceptance criteria

- Ranked risk register — complete, legible, based only on mock data, and traceable to the decision made.
- Top-three rationale — complete, legible, based only on mock data, and traceable to the decision made.
- Treatment decisions — complete, legible, based only on mock data, and traceable to the decision made.
- Owners and due dates — complete, legible, based only on mock data, and traceable to the decision made.
- Verification plan — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-05: Authorised Web-Risk Review in FauxBank

Field	Detail
Time	40 minutes
Alignment	LO1, LO3
Tool	FauxBank
Scenario	A bank training application needs a safe, evidence-based review of authentication and input-handling risks.
Mock data	mock-fauxbank-test-plan.csv, mock-test-accounts.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://pentest-fauxbank.vercel.app/

Procedure

1. Confirm the scope is limited to the supplied FauxBank training site and mock accounts; do not test any other system.
2. Review the test plan and identify the expected safe outcome for authentication, authorisation and input validation.
3. Run only the non-destructive checks listed in the plan; never attempt data destruction, denial of service or persistence.
4. Record the request context, observed behaviour, risk, affected user and reproducibility without storing real credentials.
5. Map each observation to a vulnerability category and a defensive recommendation.
6. Create a one-page responsible report with evidence, impact, remediation and escalation priority.

Evidence and acceptance criteria

- Signed scope check — complete, legible, based only on mock data, and traceable to the decision made.
- Completed test plan — complete, legible, based only on mock data, and traceable to the decision made.
- Redacted screenshots — complete, legible, based only on mock data, and traceable to the decision made.
- Risk statements — complete, legible, based only on mock data, and traceable to the decision made.
- Responsible report — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-06: Protect Data with Hashing and Encryption

Field	Detail
Time	30 minutes
Alignment	LO2, LO3
Tool	Cryptography Toolkit
Scenario	A clinic must distinguish confidentiality, integrity checking and password storage when protecting mock records.
Mock data	mock-sensitive-records.csv, mock-secrets.txt
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/cryptography-toolkit/

Procedure

1. Classify each mock data item by sensitivity and identify whether confidentiality, integrity or both are required.
2. Use the toolkit to hash two similar messages; compare the outputs and explain the avalanche effect.
3. Encrypt one mock record with a training-only key, then decrypt it and verify accuracy.
4. Explain why encryption keys must be separated from encrypted data and why hashing is not reversible encryption.
5. Design a key-handling checklist covering creation, storage, sharing, rotation, backup and destruction.
6. Remove any locally copied training secret after evidence capture; never enter real personal or business secrets.

Evidence and acceptance criteria

- Data classification — complete, legible, based only on mock data, and traceable to the decision made.
- Hash comparison — complete, legible, based only on mock data, and traceable to the decision made.
- Encrypted/decrypted sample — complete, legible, based only on mock data, and traceable to the decision made.
- Key-handling checklist — complete, legible, based only on mock data, and traceable to the decision made.
- Security explanation — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-07: Map Network Exposure and Segmentation

Field	Detail
Time	35 minutes
Alignment	LO1, LO3
Tool	IP Calculator
Scenario	A retail office needs separate zones for staff, guests, point-of-sale devices and management systems.
Mock data	mock-network-assets.csv, mock-network-requirements.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/ipcalculator/

Procedure

1. Group the mock assets by trust level, data sensitivity and operational role.
2. Use the IP Calculator to create non-overlapping training subnets sized for each group.
3. Record network address, usable host range, broadcast address and proposed gateway for each zone.
4. Draw allowed flows and deny-by-default boundaries between staff, guest, point-of-sale and management networks.
5. Identify which services, if any, need internet exposure and add a monitoring or access-control requirement.
6. Review the design for excessive trust and document one residual risk.

Evidence and acceptance criteria

- Subnet plan — complete, legible, based only on mock data, and traceable to the decision made.
- Asset-to-zone mapping — complete, legible, based only on mock data, and traceable to the decision made.
- Allowed-flow matrix — complete, legible, based only on mock data, and traceable to the decision made.
- Exposure decisions — complete, legible, based only on mock data, and traceable to the decision made.
- Residual risk — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-08: Triage Suspicious Network Traffic

Field	Detail
Time	35 minutes
Alignment	LO1, LO3
Tool	PCAP Analyzer
Scenario	A workstation generates unusual DNS and outbound traffic after a user opens an attachment.
Mock data	mock-traffic.pcap, mock-packet-summary.csv, mock-known-services.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/pcapanalyzer/

Procedure

1. Upload only the supplied synthetic mock-traffic.pcap to the PCAP Analyzer; do not upload production captures.
2. Identify top talkers, unusual ports, repeated destinations, DNS lookups and cleartext indicators.
3. Correlate packet observations with mock-packet-summary.csv and mark any disagreement.
4. Build a five-event timeline and identify the earliest reliable sign of compromise.
5. Decide whether to monitor, block, isolate or escalate; include potential business impact.
6. Write an evidence-preserving handover note without including unnecessary personal data.

Evidence and acceptance criteria

- Traffic findings — complete, legible, based only on mock data, and traceable to the decision made.
- Five-event timeline — complete, legible, based only on mock data, and traceable to the decision made.
- Earliest reliable signal — complete, legible, based only on mock data, and traceable to the decision made.
- Containment decision — complete, legible, based only on mock data, and traceable to the decision made.
- Handover note — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-09: Design and Test a Detection Rule

Field	Detail
Time	30 minutes
Alignment	LO3
Tool	Regex Generator
Scenario	A security team needs a transparent rule for repeated failed logins and suspicious usernames.
Mock data	mock-auth.log, mock-detection-requirements.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/regexgenerator/

Procedure

1. Read the detection requirements and label the supplied log lines as expected match or expected non-match.
2. Use Regex Generator to build a pattern for failed-login lines while capturing timestamp, username and source IP.
3. Test every line and calculate true positives, false positives and false negatives.
4. Refine the expression to reduce noise without excluding the malicious samples.
5. Define a threshold and time window for escalation; explain the cost of a threshold that is too low or too high.
6. Document the rule purpose, assumptions, limitations, owner and review date.

Evidence and acceptance criteria

- Tested regex — complete, legible, based only on mock data, and traceable to the decision made.
- Confusion matrix — complete, legible, based only on mock data, and traceable to the decision made.
- Threshold decision — complete, legible, based only on mock data, and traceable to the decision made.
- Rule documentation — complete, legible, based only on mock data, and traceable to the decision made.
- Escalation criteria — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

Lab-10: Integrated Incident Response and Escalation

Field	Detail
Time	45 minutes
Alignment	LO1–LO3
Tool	Integrated toolkit
Scenario	A supplier-payment email, endpoint alert and suspicious network connection may form one business-impacting incident.
Mock data	mock-incident-brief.md, mock-timeline.csv, mock-escalation-contacts.csv, mock-risk-register.csv
Safety	Use only the supplied mock data and the named training environment. Stop if the target or scope differs.

Open tool: https://alfredang.github.io/cybersecuritysimulator/

Procedure

1. Read the incident brief and assign roles: incident lead, evidence recorder, communications lead and business owner.
2. Correlate email, endpoint, identity and network events into one timeline; state which events are facts and which are hypotheses.
3. Assess impact to confidentiality, integrity, availability, safety, finance, reputation and legal obligations.
4. Choose immediate actions that are reversible, evidence-preserving and proportionate to business risk.
5. Use the contact matrix to escalate to the correct internal and external parties; do not contact real organisations during the exercise.
6. Deliver a three-minute incident briefing: situation, evidence, impact, actions, decisions required and next update time.
7. Complete the mock risk register and one after-action improvement with owner and due date.

Evidence and acceptance criteria

- Correlated timeline — complete, legible, based only on mock data, and traceable to the decision made.
- CIA and business-impact assessment — complete, legible, based only on mock data, and traceable to the decision made.
- Decision log — complete, legible, based only on mock data, and traceable to the decision made.
- Escalation record — complete, legible, based only on mock data, and traceable to the decision made.
- Three-minute briefing — complete, legible, based only on mock data, and traceable to the decision made.
- After-action improvement — complete, legible, based only on mock data, and traceable to the decision made.

Reflection: What evidence would make you reverse your decision, and who would need to know?

30-day transfer plan

When	Action	Owner	Evidence
24 hours	Enable MFA on priority accounts; confirm incident contacts; test one restore		
7 days	Remove dormant access; patch exposed assets; verify payment-change procedure		
30 days	Run a tabletop exercise; review suppliers; close top three risks		

Source register

IBM — Cybersecurity overview: https://www.ibm.com/think/topics/cybersecurity

Cisco — What is cybersecurity?: https://www.cisco.com/site/us/en/learn/topics/security/what-is-cybersecurity.html

Microsoft — What is cybersecurity?: https://www.microsoft.com/en-us/security/business/security-101/what-is-cybersecurity

Kaspersky — Cybersecurity definition: https://www.kaspersky.com/resource-center/definitions/what-is-cyber-security

Fortinet — Cybersecurity glossary: https://www.fortinet.com/resources/cyberglossary/what-is-cybersecurity

Check Point — What is cybersecurity?: https://www.checkpoint.com/cyber-hub/cyber-security/what-is-cybersecurity/

CSA Singapore — Cybersecurity guidance: https://www.csa.gov.sg/

NCSC — Understanding vulnerabilities: https://www.ncsc.gov.uk/collection/vulnerability-management/understanding-vulnerabilities

OWASP — Vulnerabilities and SQL injection: https://owasp.org/www-community/vulnerabilities/

CrowdStrike — Types of malware: https://www.crowdstrike.com/en-us/cybersecurity-101/malware/types-of-malware/

CISA — Real-world case studies: https://www.cisa.gov/real-world-case-studies

Singapore Police Force — Annual Scam and Cybercrime Brief 2025: https://www.police.gov.sg/-/media/SPF/Media-Room/Statistics/Annual-Scams-and-Cybercrime-Brief-2025/Annual-Scam-and-Cybercrime-Brief-2025.pdf

SingHealth data breach — Ministry of Health Singapore — SingHealth's IT System Target of Cyberattack: https://www.moh.gov.sg/newsroom/singhealth%27s-it-system-target-of-cyberattack/

WannaCry and the NHS — UK National Audit Office — Investigation: WannaCry Cyber Attack and the NHS: https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/

Equifax breach — U.S. House Committee on Oversight — The Equifax Data Breach: https://oversight.house.gov/report/the-equifax-data-breach/

SolarWinds supply-chain compromise — CISA — Active Exploitation of SolarWinds Software: https://www.cisa.gov/news-events/alerts/2020/12/13/active-exploitation-solarwinds-software

Colonial Pipeline — CISA — IAM Case Study: Colonial Pipeline: https://www.cisa.gov/sites/default/files/2023-12/IAM_EDUCATIONAL_AID_TALKING_POINTS_508C.pdf

Log4Shell exploitation — CISA — Mitigating Log4Shell and Log4j Vulnerabilities: https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-356a

MOVEit mass exploitation — CISA — CL0P Exploits MOVEit Vulnerability: https://www.cisa.gov/sites/default/files/2023-06/aa23-158a-stopransomware-cl0p-ransomware-gang-exploits-moveit-vulnerability_7.pdf

MGM Resorts cyber incident — U.S. Securities and Exchange Commission — MGM Resorts International Form 8-K: https://www.sec.gov/Archives/edgar/data/789570/000119312523251667/d461062d8k.htm

Singapore commodity-trader BEC — Singapore Police Force — Recovery of Over USD 6.6 Million in BEC Case: https://www.police.gov.sg/media-hub/news/2026/05/20260505_international_cooperation_leads_to_the_recovery_of_over

Target payment-card breach — U.S. Senate Committee on Commerce — Target's Missed Opportunities to Stop a Data Breach: https://www.commerce.senate.gov/press/dem/release/rockefeller-staff-report-details-targets-missed-opportunities-to-stop-massive-data-breach-2014-3/

NotPetya disruption at Maersk — UK Department for Transport — Cyber Security for Ports and Port Systems: https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/546160/cyber-security-for-ports-and-port-systems-code-of-practice.pdf

Marriott Starwood data breach — UK Information Commissioner's Office — Marriott International Monetary Penalty Notice: https://ico.org.uk/media/action-weve-taken/mpns/2618524/marriott-international-inc-mpn-20201030.pdf

Capital One cloud data breach — U.S. Department of Justice — Seattle Tech Worker Arrested for Data Theft: https://www.justice.gov/usao-wdwa/pr/seattle-tech-worker-arrested-data-theft-involving-large-financial-services-company

Norsk Hydro LockerGoga ransomware — UK National Cyber Security Centre — What Is OT Malware?: https://www.ncsc.gov.uk/blog-post/what-is-ot-malware

Change Healthcare cyberattack — U.S. Securities and Exchange Commission — UnitedHealth Group Form 8-K, 21 February 2024: https://www.sec.gov/Archives/edgar/data/731766/000073176624000045/unh-20240221.htm